Brainstorming and Ideation Phase

Script-Controlled ACL - Restrict Record Access Based on Field Value

ServiceNow Platform

Project Title	Script-Controlled ACL - Restrict Record Access Based on Field Value
Platform	ServiceNow (Table, Roles, ACL)
Team Size	5 Members
Lab Duration	3 hrs
Phase	1. Brainstorming and Ideation Phase

Team Members

Member	Name	Role
Member 1	Swetha V	Team Lead
Member 2	Vaitheeshwari S	Requirements
Member 3	Swetha T	Table, Fields, Data
Member 4	Abinesh V	Users, Roles, ACL Scripts
Member 5	Anbuselvam M	Test cases

1. Introduction

This document records the brainstorming and ideation phase of our group project. The team identified a real security problem in record-based applications, explored several ideas, and selected the one to implement on the ServiceNow platform.

2. Problem Statement

In an institution, student records contain sensitive data such as email, phone number, faculty and branch. If every user with table access can see every record, students or staff of one branch can view another branch's data. The institution needs a way to make sure that **only users of the EEE branch can view records whose Branch is EEE**, while administrators keep full access.

3. Objectives

- Restrict record visibility using a script-controlled Access Control List (ACL).
- Combine **role checks** and **record field values** (Branch = EEE) in one access decision.
- Extend the same idea to CREATE, WRITE and DELETE operations using separate roles.
- Verify the behaviour by impersonating different users.

4. Brainstorming Session - Ideas Considered

#	Idea	Pros	Cons
1	Hide records using client script / UI policy	Easy to build	Not secure; data still reachable via list, API, URL

2	Use Business Rule (Before Query) to filter records	Filters at query level	Harder to maintain; not an ACL-level control
3	**Script-controlled ACL with roles and data condition (Selected)**	Server-side, secure, standard ServiceNow feature, covers list, form and API	Needs security_admin role and careful testing
4	Separate table per branch	Simple separation	Data duplication; poor scalability

5. Selected Idea and Justification

The team selected **Idea 3: Script-controlled ACL**. ACLs are evaluated on the server for every list, form, report and API request, so the restriction cannot be bypassed from the browser. It also lets us give fine-grained permissions (read, create, write, delete) through custom roles bb1, bb2, bb3 and bb4.

6. Stakeholders / Users Affected

User Type	Need
EEE branch user (role bb1)	View only EEE records
User without any role	Should see no records
Administrator	Full access to all records
Faculty / staff (with bb2-bb4)	Create, edit and delete EEE records as permitted

7. Feasibility Check

Area	Assessment
Technical	Feasible - uses standard ServiceNow tables, roles and ACLs
Time	Feasible - lab is planned for 3 hours
Resources	ServiceNow instance with admin access and security_admin elevation
Risk	Low - test on a sample table (u_institution_details)

8. Team Roles Agreed in Brainstorming

Member	Name	Role
Member 1	Swetha V	Team Lead
Member 2	Vaitheeshwari S	Requirements
Member 3	Swetha T	Table, Fields, Data
Member 4	Abinesh V	Users, Roles, ACL Scripts
Member 5	Anbuselvam M	Test cases

9. Outcome of Phase 1

- Problem statement finalised.
- Solution approach selected: script-controlled ACL.
- Roles and responsibilities assigned to all 5 members.
- Ready to move to Requirement Analysis.